



Christophe PICHAUD
Architecte Microsoft chez
'Modern Applications by Devoteam'
christophepichaud@hotmail.com
www.windowscpp.com

Reverse Engineering et analyse de virus

La programmation système est un domaine où les connaissances vont du système d'exploitation, aux API, aux outils et aux techniques de fonctionnement des logiciels. Le reverse engineering (RE), c'est le fait de découvrir, sans le code source, comment fonctionne une application ou un système à l'aide de ses connaissances sur le système.

niveau
200

Exemple d'applications

Le meilleur exemple d'utilisation du RE est l'analyse des virus. On veut savoir quels sont les effets nocifs que va provoquer un module. On le désassemble et on analyse son code assembleur pour savoir ce qu'il va faire. On va noter les appels systèmes et déduire les différentes techniques et algorithmes utilisés. Pour déduire les appels systèmes, on dispose aussi d'autres outils qui sont capables de nous donner des informations pertinentes. Avant, un bref rappel.

Construction d'un système d'exploitation

Simplifions les choses : l'OS est bâti avec une couche système et un mode user. Dans le mode kernel, il y a le noyau, les sous-systèmes et les drivers et dans le mode user, les applications. Sous Windows, les modules kernel sont liés (liés à l'édition de liens) à kernel32.lib. En mode user, les modules sont liés à kernel32.lib et user32.lib et généralement gdi32.lib.

Le système d'exploitation est fait en C donc s'y retrouve aussi le runtime du C à savoir MSVCRTxxx.dll. Donc un module user lambda se voit lié à ces 4 DLLs. C'est valable dans 90% des cas. La question est la suivante : comment puis-je le savoir?

Il y a plusieurs possibilités. 1ère option : télécharger les Windows Server Support Tools dans lequel il y a depends.exe. 2ème option : utiliser un environnement Visual Studio ou un Windows SDK qui fournit dumpbin.exe.

Depends.exe

Vous lancez depends.exe et vous lui faites un drag-and-drop d'un module dedans. Il va vous donner la liste des modules dont dépend

votre module. Pour chaque module, il y a aussi la liste des fonctions utilisées (importées). ¹

Dumpbin.exe

Vous lancez dumpbin.exe /xxx et il vous donne le plein d'informations sur votre module.

Exemple : dumpbin /imports OpenConsole.exe

Cette commande vous affiche en texte, l'équivalent de depends.

Autre exemple :

dumpbin /dependents OpenConsole.exe

Cette commande donne la liste des DLLs qui seront automatiquement chargées.

Microsoft (R) COFF/PE Dumper Version 14.16.27030.1

Copyright (C) Microsoft Corporation. All rights reserved.

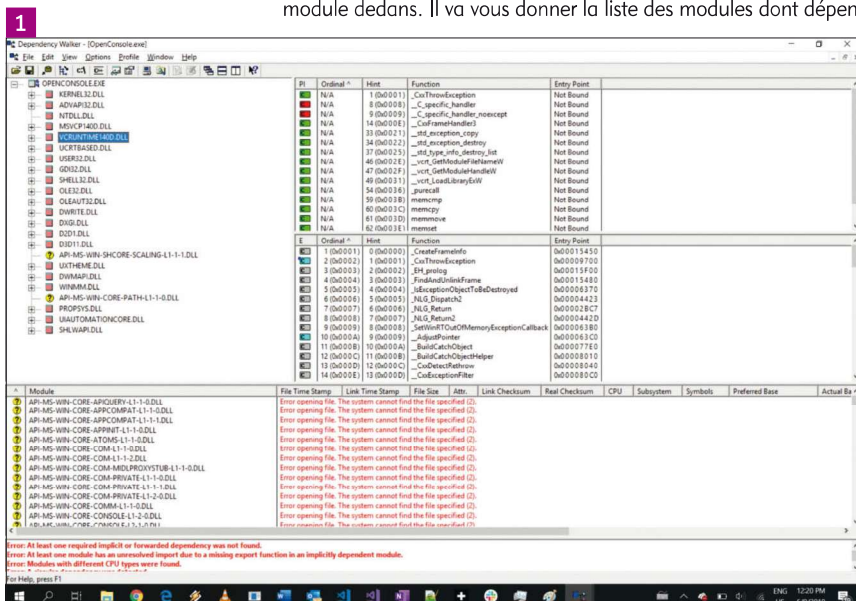
Dump of file OpenConsole.exe

File Type: EXECUTABLE IMAGE

Image has the following dependencies:

KERNEL32.dll
ADVAPI32.dll
ntdll.dll
MSVCP140D.dll
VCRUNTIME140D.dll
ucrtbased.dll
USER32.dll
GDI32.dll
SHELL32.dll
ole32.dll
OLEAUT32.dll
DWrite.dll
dxgi.dll
d2d1.dll
d3d11.dll
api-ms-win-shcore-scaling-l1-1-1.dll
UxTheme.dll
dwmapi.dll
WINMM.dll
api-ms-win-core-path-l1-1-0.dll
PROPSYS.dll
UIAutomationCore.DLL
SHLWAPI.dll

Summary



```
7000 .data
2000 .msvcjmc
32000 .pdata
143000 .rdata
4000 .reloc
9000 .rsrc
296000 .text
```

A partir de là, on a le tableau des modules qui seront chargés. Cela permet de faire des hypothèses.

Environnement de simulation

Le meilleur moyen de visualiser ce que fait un module est de le lancer et d'observer, d'analyser et de prendre des « traces ». L'outil regmon de SysInternals permet d'enregistrer la liste des opérations faites sur la base de registres. C'est très intéressant car ces outils essaient pour la plupart de se rendre invisibles sur le système. Voir l'article de Janvier et Février sur les rootkits pour plus d'informations. Attention, pour tester ces modules sensibles, il faut se mettre en mode bac à sable dans une machine virtuelle sinon c'est la catastrophe... Je pense que vous vous en doutez.

Souvent les scénarios des outils malveillants vont de la dissimulation vis à vis des anti-virus, le dépôt de backdoor ou de keylogger (donc enregistrement de drivers avec de faux certificats), l'ouverture de portes dans le firewall, jusqu'à l'enregistrement en autorun de certaines applications.

ProcessExplorer de SysInternals va nous permettre de voir, comme TaskManager, la liste des applications qui tournent sur notre OS et surtout le chemin depuis lequel ils sont lancés. Les logiciels malveillants se cachent dans les profiles, dans system32 ou dans programfiles avec des noms passe-partout.

L'art du Reverse Engineering

Le reverse engineering, c'est comme un travail de lutte anti-terroriste. On étudie comment il se distribue, comment il se lance, comment il enregistre ses sous modules et ce qu'il projette de faire dans différents scénarios. L'art se distingue, car il faut connaître les modules de Windows pour savoir quel type d'opération va être réalisé. Exemple : si la fonction CreateNamedPipes est utilisée, on va chercher à savoir quel est le nom du pipe. On va parier que le nom va être caché via l'ajout de \$ en préfix. L'utilisation de ProcessExplorer de SysInternals peut les lister. On utilise des méthodes d'investigations. On se doit d'être patient car parfois, le module principal charge des modules annexes, des extensions, des plugins. En programmation système, le couple LoadLibrary/GetProcAddress est terrible. Ces sont les API systèmes qui permettent de charger un module et d'avoir accès à une fonction pour l'exécuter. L'avantage, c'est que cela est réalisé de façon dynamique et non statique. C'est invisible pour depends ou dumpbin.

Appels dynamiques

Imaginez que le module reçoive une instruction sur un port tcp/ip et se voie transférer un module avec un nom de fonction. Il enregistre le flow de data sur disque, le renomme en dll et appelle une fonction. Indétectable !

C'est comme ça que sont faits les virus modernes. Par étages.

Win32, l'API ultime

Pour maîtriser la conception d'un virus, il faut maîtriser le host, c'est à dire le système d'exploitation. Il en va de la connaissance des API systèmes. Dans le monde Windows, on appelle cela les API Win32. On y retrouve toutes les API fournies par l'OS. La documentation Microsoft de développement a été complètement refondue (une fois de plus?) et le lien valide est : <https://docs.microsoft.com/en-us/windows/desktop/api/>

Pour les DLL, voici le lien : <https://docs.microsoft.com/en-us/windows/desktop/Dlls/dynamic-link-library-functions>

Une DLL c'est quoi ?

Une Dynamic Loaded Library ou DLL est un module dynamique. Il se charge à la volée car un autre module en a besoin ; dans ce cas c'est une dépendance et l'OS la charge automatiquement car la liaison est statique. Sinon, le chargement est dynamique, c'est à dire qu'un code fait appelle à LoadLibrary pour charger explicitement une DLL.

```
HMODULE LoadLibraryA( LPCSTR lpLibFileName );
FARPROC GetProcAddress( HMODULE hModule, LPCSTR lpProcName );
```

LPCSTR est le type Windows pour const char *.

HMODULE est un handle système. FARPROC est un épointeur de fonction (void *()).

```
typedef void (WINAPI *PGNSI)(LPSYSTEM_INFO);
```

// Call GetNativeSystemInfo if supported or GetSystemInfo otherwise.

```
PGNSI pGNSI;
SYSTEM_INFO si;
ZeroMemory(&si, sizeof(SYSTEM_INFO));
```

```
pGNSI = (PGNSI) GetProcAddress(
    GetModuleHandle(TEXT("kernel32.dll")), "GetNativeSystemInfo");
if(NULL != pGNSI)
{
    pGNSI(&si);
}
```

Les virus

Les virus sont fabriqués en C/C++ car le C/C++ est le langage des systèmes d'exploitation. Après tout, un virus est un programme comme un autre. OK, il essaie de dissimuler les informations et d'être discret mais il n'y a rien d'illégal à écrire sur disque, faire des fichiers cachés, crypter les communications, enregistrer des drivers, etc. Ce qui est illégal, c'est d'essayer de pénétrer dans le système de quelqu'un d'autre et de faire du vol de données ou de l'utilisation à des fins illicites. Nuance !

Dans une entreprise, j'ai le droit de mettre un keylogger pour surveiller mes employés, oui ou non ? J'ai le droit de filtrer toutes les communications qui sortent sur la passerelle internet, oui ou non ? J'ai le droit de dissimuler des fichiers dans des endroits non surveillés, oui ou non ? J'ai le droit de stocker des données dans des JPEG, oui ou non ?

En tant que chercheur en informatique, vous avez droit à tout tant

que c'est de la recherche. Vous allez certainement installer plusieurs fois des VM à force de casser vos environnements... ou de rebooter à force de provoquer des blue screen si vous touchez au mode kernel:)

Les débogueurs

Sous Windows, le must c'est WinDBG. Il permet de lancer les applications en pas à pas et c'est un outil gratuit disponible dans le Windows Sdk. Si les symboles de débogage sont installés, WinDBG va afficher le nom des API systèmes au lieu de leur offset dans la liste des fonctions.

Les désassembleurs

Il existe des applications qui transforment le code binaire en code

assembleur. On peut découvrir des trucs extraordinaires. Exemple : au chargement du programme, on s'aperçoit que le programme « décrypte des pages de texte » et les transforme en pages qui peuvent s'exécuter c.a.d en code. Cela permet d'être invisible vis à vis des anti-virus. Sous Windows le must est Hex-Rays IDA Pro. C'est un outil payant.

Conclusion

Un virus n'est qu'un programme qui fait des opérations à votre insu. Il vole vos données, les envoie via votre box internet à un serveur host ; il est contrôlé à distance pour recevoir des instructions ou des modules complémentaires. Le RE sur ces modules n'est qu'un moyen scientifique de connaître leur fonctionnement et de limiter leurs dégâts car nous n'avons pas le code source...

Complétez votre collection

Prix unitaire : 6,50€



Lot complet

1 CADEAU À OFFRIR !

39,99€

(au lieu 45,50 €)



- | | |
|--|--|
| ☐ 218 : <input type="text"/> ex | ☐ 225 : <input type="text"/> ex |
| ☐ 219 : <input type="text"/> ex | ☐ 228 : <input type="text"/> ex |
| ☐ 220 : <input type="text"/> ex | ☐ 229 : <input type="text"/> ex |
| ☐ 221 : <input type="text"/> ex | ☐ 230 : <input type="text"/> ex |

☐ Lot complet :
218 - 219 - 220 - 221
225 - 228 - 229
39,99 €

Commande à envoyer à :
Programmez!
57 rue de Gisors - 95300 Pontoise

soit exemplaires x 6,50 € = € soit au **TOTAL** = €

Prix unitaire : 6,50 €
(Frais postaux inclus)

☐ M. ☐ Mme ☐ Mlle Entreprise : Fonction :

Prénom : Nom :

Adresse :

Code postal : Ville :

E-mail : @

Règlement par chèque à l'ordre de Programmez ! | Disponible sur www.programmez.com